PHASE 1 — CISO/ISSO PROGRAM BUILD

Applicability, Scoping & Framework Selection Register

Document Owner: Chief Information Security Officer / ISSO
Classification: Internal / Portfolio Reference
Version: 1.1 (Draft — Gate 1 pending)
Last Reviewed: 2026-10-22
Next Review Due: At Gate 1 sign-off, then annually
Approved By: [Insert Approver / Title]

Table of Contents

(Updates automatically on open in Word. If blank, right-click and choose "Update Field.")

Document Control

Field	Value
Document ID	REF-02-001
Document type	Register (Phase 1 gating artifact)
Status	Draft
Owner	CISO / Program Owner
Approver	Gate 1 reviewers (Legal, Privacy, Contracts, Management)
Applies to	Reference Enterprise — all business units, systems, data, and third parties
Authoritative sources	NIST CSF 2.0; ISO/IEC 27001:2022; NIST SP 800-53 Rev. 5; CIS Controls v8; statutes/standards listed in Section 4
Related documents	REF-00-001 Engagement Charter; REF-08-001 Unified Control Library (Phase 3); REF-08-002 Assumptions & Decisions Log
Supersedes	Version 1.0 (2026-09-03)

1. Purpose

This register determines which legal, regulatory, contractual, certification, and voluntary obligations apply to the Reference Enterprise, on what trigger, and which are explicitly out of scope and why. It is the gating artifact for Gate 1. No control in the unified control library (Phase 3) and no document in the program library (Phase 5 onward) should exist without tracing to a row in this register or to an approved voluntary-framework decision in Section 3.

The Reference Enterprise is a composite organization built for portfolio, skill-building, and interview use. It is deliberately scoped broadly (all major data types, commercial and federal tracks) so that overlay modules can be removed wholesale when the package is adapted to a real organization, without leaving orphaned cross-references.

2. Scope Statement

2.1 In scope

- All business units and workforce (employees, contractors, interns) of the Reference Enterprise
- All information systems, on-premises and cloud (IaaS/PaaS/SaaS), including customer-facing applications and the CI/CD pipeline
- All data in any format, classified per the Data Classification Policy as Public, Internal, Confidential, or Restricted
- Third parties that access, process, store, or transmit organizational data or connect to organizational systems
- One internal AI-assisted tool (support/analytics copilot) — narrowly scoped

2.2 Out of scope (with rationale)

- Operational technology / industrial control systems — no OT assets in the composite profile; the ISA/IEC 62443 overlay is excluded, not deferred
- National-security systems — not applicable to a commercial enterprise; CNSSI requirements excluded
- Medical device manufacturing — excluded; FDA premarket cybersecurity requirements do not apply

2.3 Inactive but retained (federal track)

The federal/CUI overlay (FAR/DFARS, NIST SP 800-171/171A, CMMC, FedRAMP, RMF-based authorization) is built as a separate module and held inactive. It activates on a single trigger — signing a federal contract or subcontract that flows down safeguarding clauses or delivers CUI — without restructuring the commercial core. This directly implements the instruction to keep commercial and federal standards separable.

3. Framework Architecture Decision

The program maintains one authoritative control library. Every other framework, regulation, and customer requirement maps inward to it rather than to each other. This is the mechanism that prevents duplicate, contradictory control sets.

Layer	Selection	Role in the program	Why this choice
Enterprise outcome taxonomy	NIST CSF 2.0	Current/Target Profile; Board-level posture reporting	Universal, vendor-neutral, adds the Govern function; recognized by every auditor and regulator
Management system	ISO/IEC 27001:2022 / 27002:2022	ISMS structure: management review, internal audit, continual improvement; certification pathway	Supplies the governance scaffolding CSF and 800-53 do not fully specify
Authoritative control library	NIST SP 800-53 Rev. 5	Single control catalog; org control IDs (ORG-AC-001 etc.) map to 800-53 first	Most granular public catalog; published crosswalks to ISO 27001 Annex A and 800-171; direct lineage to the federal track
Risk-based baseline tiering	CIS Controls v8, IG1 / IG2 / IG3	Defines minimum-viable (IG1) vs. target-state (IG3) implementation depth	Defensible 'where do you start' answer for a greenfield build
Threat-informed validation	MITRE ATT&CK	Detection-coverage mapping in Phase 8	Turns control inventory into an answer to 'can the adversary still get through'
System authorization method	NIST RMF (SP 800-37 Rev. 2)	Federal-track only: categorize → select → implement → assess → authorize → monitor	Required pattern for FISMA/FedRAMP/CMMC-style authorizations

- Crosswalks in this package are labeled Direct, Partial, Supporting, or No Reliable Mapping. A mapping is an aid, never proof of equivalence.
- Overlays (Section 4) add only the incremental requirements not already satisfied by the core; they never restate core controls.

4. Applicability Register

Each obligation is recorded with the fields the master engagement method requires. Status values: Applicable; Applicable — Overlay (active); Overlay — Inactive (retained, triggers documented); Not Applicable (rationale documented). Rows are grouped by authority type.

4.1 Voluntary frameworks and certification objectives (Core)

Source	Authority type	Trigger	Covered data / systems	Validation authority	Conclusion
NIST CSF 2.0	Voluntary framework	Enterprise design choice	Entire program	Internal (self-assessed profile)	Applicable — Core
ISO/IEC 27001:2022	Voluntary; certification objective	Target certification	ISMS scope = Section 2.1	Accredited certification body	Applicable — Core
NIST SP 800-53 Rev. 5 / 53A / 53B	Voluntary control catalog (federal origin)	Selected as unified control library	All systems	Internal; assessors for federal track	Applicable — Core
CIS Controls v8	Voluntary	Baseline tiering model	All systems	Internal	Applicable — Core
SOC 2 (AICPA Trust Services Criteria)	Customer assurance / contractual	B2B customers require attestation	Services in the system description	Licensed CPA firm	Applicable — Core (Security TSC minimum)
NIST SSDF (SP 800-218) / OWASP ASVS	Voluntary	In-house software development with CI/CD	Application code, pipeline	Internal; customer questionnaires	Applicable — Core

4.2 Legal and regulatory obligations

Source	Jurisdiction	Trigger	Covered data / systems	Validation authority	Conclusion
State breach-notification statutes (all 50 states + DC/territories)	US — state	PII of residents held; breach discovered	Customer and employee PII	State attorneys general	Applicable — Core
CCPA / CPRA and other comprehensive state privacy laws	US — state	Residents' personal data processed above statutory thresholds	Customer PII	State privacy regulators (e.g., CPPA)	Applicable — Overlay (privacy/US)
GDPR / UK GDPR	EU / UK	EU/UK data subjects served (assumed customer base)	Customer PII; subprocessor chain	EU/UK supervisory authorities	Applicable — Overlay (privacy/EU)
HIPAA Security, Privacy & Breach	US — federal	PHI processed as covered entity	PHI systems and BAAs	HHS Office for Civil Rights	Applicable — Overlay (healthcare)

Source	Jurisdiction	Trigger	Covered data / systems	Validation authority	Conclusion
Notification Rules; HITECH		or business associate			
GLBA Safeguards Rule	US — federal	Only if organization is a 'financial institution' under the FTC's broad definition	Customer financial PII	FTC	[MANAGEMENT DECISION REQUIRED] — Not Applicable pending industry confirmation (A-07)
SEC cybersecurity disclosure rules (Reg S-K Item 106; Form 8-K Item 1.05)	US — federal	Only if publicly traded	Enterprise	SEC	Not Applicable — private company (A-06)
NYDFS Part 500 / FFIEC / FINRA	US — state/federal, financial sector	Only if a covered financial entity	Enterprise	NYDFS / banking regulators	Not Applicable — no sector trigger (A-07)
NERC CIP	US/Canada — energy	Bulk electric system assets	None	NERC / FERC	Not Applicable — no sector trigger
FERPA / COPPA	US — federal	Student education records; children under 13	None	Dept. of Education / FTC	Not Applicable — no sector trigger
FDA medical device cybersecurity (FD&C Act §524B)	US — federal	Manufacture of cyber devices	None	FDA	Not Applicable — excluded by scope (2.2)

4.3 Contractual and industry-mandated obligations

Source	Authority type	Trigger	Covered data / systems	Validation authority	Conclusion
PCI DSS v4.0.1	Contractual (card-brand mandate via acquirer)	Cardholder data stored, processed, or transmitted	Cardholder data environment (CDE) and connected systems	QSA / acquirer; SAQ or ROC + AOC	Applicable — Overlay (payments)
Customer security addenda / DPAs / questionnaires	Contractual	Each executed customer agreement	Per contract	Customer; internal Contracts	Applicable — Core ([CONTRACT REVIEW REQUIRED] per agreement)
Cyber-insurance policy conditions	Contractual	Policy in force	Enterprise (typically MFA, backup, EDR warranties)	Carrier	Applicable — Core ([CONTRACT REVIEW REQUIRED])
FAR 52.204-21 (basic safeguarding of FCI)	Contractual — federal	Any federal contract involving	FCI systems	Contracting officer	Overlay — Inactive (federal track)

Source	Authority type	Trigger	Covered data / systems	Validation authority	Conclusion
		Federal Contract Information			
DFARS 252.204-7012 / -7019 / -7020 / -7021	Contractual — DoD	DoD contract with CUI; CMMC clause	CUI enclave	DoD; DIBCAC; C3PAO	Overlay — Inactive (federal track)
NIST SP 800-171 Rev. 3 / 171A	Contractual flow-down	CUI received under a federal contract	CUI enclave	C3PAO / DIBCAC	Overlay — Inactive (federal track) — [SOURCE VERSION VALIDATION REQUIRED]: confirm which revision the governing contract incorporates
CMMC (32 CFR Part 170)	Contractual — DoD	Solicitation specifies CMMC level	CUI/FCI scope	C3PAO (Level 2); DIBCAC (Level 3)	Overlay — Inactive (federal track)
FedRAMP (Rev. 5 baselines)	Contractual — federal cloud	Selling cloud services to federal agencies	Cloud service offering boundary	FedRAMP PMO / agency AO / 3PAO	Overlay — Inactive (federal track)

4.4 Emerging-technology governance

Source	Authority type	Trigger	Covered systems	Validation authority	Conclusion
NIST AI RMF 1.0 + Generative AI Profile	Voluntary	Internal AI-assisted tool in use	The copilot and its data inputs/outputs	Internal	Applicable — Overlay (AI), narrow scope
ISO/IEC 42001:2023	Voluntary; certification objective	Only if AI management-system certification is pursued	AI system(s)	Accredited certification body	Not pursued — [MANAGEMENT DECISION REQUIRED]
EU AI Act	Legal — EU	AI system placed on EU market or output used in EU; risk tier determines obligations	The copilot, if EU-facing	EU/member-state market surveillance	[LEGAL REVIEW REQUIRED] — likely minimal-risk tier; transparency obligations only
Colorado AI Act / state AI laws	Legal — US state	High-risk AI used in consequential decisions	The copilot, if used for covered decisions	State AG	[LEGAL REVIEW REQUIRED] — Not Applicable if copilot makes no consequential decisions

5. Data, Service, and Technology Scoping Matrix

Maps each data category and technology domain to its classification tier and governing overlay(s). Phase 6 system packages derive their FIPS 199 categorization and control tailoring from this table, not from scratch.

Data / system category	Classification	Governing overlay(s)	In boundary?
Employee PII (HR, payroll, benefits)	Confidential	State breach/privacy law	Yes
Customer PII	Confidential	State privacy law; GDPR/CCPA	Yes
Protected Health Information (PHI)	Restricted	HIPAA / HITECH	Yes
Cardholder data (PAN, SAD)	Restricted	PCI DSS v4.0.1	Yes — CDE segmented
Controlled Unclassified Information (CUI)	Restricted	NIST 800-171 / CMMC / DFARS	No — enclave defined but inactive
Federal Contract Information (FCI)	Confidential	FAR 52.204-21	No — inactive
Trade secrets, source code, IP	Confidential–Restricted	Core; SSDF	Yes
Authentication secrets, keys, tokens	Restricted	Core (IA, SC families)	Yes
AI copilot inputs/outputs	Inherits input classification	NIST AI RMF overlay	Yes — narrow scope
Azure (Entra ID, Intune, Defender, workloads)	Infrastructure	Core; cloud shared-responsibility	Yes
AWS Linux workloads	Infrastructure	Core; cloud shared-responsibility	Yes
On-prem Active Directory / Windows Server	Infrastructure	Core; CIS Benchmarks	Yes
SaaS (collaboration, HR/payroll, ticketing)	Infrastructure	Core; vendor risk overlay	Yes
CI/CD pipeline and source repositories	Infrastructure	Core; SSDF / ASVS	Yes

6. Standards and Obligations Version Register

The master method requires every cited source to carry version, status, and verification data. This register was authored without live retrieval against publisher sites, so every row carries [SOURCE VERSION VALIDATION REQUIRED] until checked against the named publisher. Versions shown are the author's best understanding as of 2026-10-22.

Source	Version / edition used	Status	Publisher to verify	Verified
NIST CSF	2.0 (Feb 2024)	Final	nist.gov/ cyberframework	No
NIST SP 800-53 / 53A / 53B	Rev. 5 (with Rev. 5.1.1 updates)	Final	csrc.nist.gov	No

Source	Version / edition used	Status	Publisher to verify	Verified
NIST SP 800-171 / 171A	Rev. 3 (May 2024)	Final; contracts may still cite Rev. 2	csrc.nist.gov	No — transitional conflict likely
NIST SP 800-37	Rev. 2	Final	csrc.nist.gov	No
NIST SP 800-218 (SSDF)	1.1	Final	csrc.nist.gov	No
NIST AI RMF	1.0 + Generative AI Profile (NIST AI 600-1)	Final	nist.gov/ai (AI RMF resource center)	No
ISO/IEC 27001 / 27002	2022	Final; 2013 withdrawn	iso.org	No
ISO/IEC 42001	2023	Final	iso.org	No
CIS Controls	v8 (v8.1 refresh)	Final	cisecurity.org	No
PCI DSS	v4.0.1	Final; future-dated requirements effective Mar 2025	pcisecuritystandards.org	No
CMMC Program	32 CFR Part 170 (final rule)	Final; phased rollout	dodcio.defense.gov/cmmc	No
FedRAMP	Rev. 5 baselines; FedRAMP 20x in progress	Final / transitional	fedramp.gov	No
HIPAA Security Rule	45 CFR Part 164 Subpart C; proposed update (Jan 2025 NPRM)	Final; NPRM pending	hhs.gov/hipaa	No — monitor NPRM
SOC 2 TSC	2017 TSC with 2022 points of focus	Final	aicpa-cima.com	No
GDPR	Regulation (EU) 2016/679	Final	eur-lex.europa.eu	No
EU AI Act	Regulation (EU) 2024/1689; staged applicability	Final; phased	eur-lex.europa.eu	No

7. Applicability Decision Tree

Used when onboarding a new system, dataset, contract, or vendor to determine which overlays attach. Ask in order; stop adding overlays when no further trigger fires.

1. Does the system or process touch personal data of US residents? → State breach-notification (always) + state privacy overlay if thresholds met.
2. Does it touch personal data of EU/UK residents? → GDPR/UK GDPR overlay; confirm lawful basis, transfer mechanism, subprocessor chain.
3. Does it touch PHI, or is the organization acting as a business associate? → HIPAA overlay; BAA required.
4. Does it store, process, or transmit cardholder data, or connect to a system that does? → PCI DSS overlay; CDE boundary review.

5. Is it under a federal contract, or does it receive FCI or CUI? → Activate federal track (FAR/DFARS/800-171/CMMC); RMF authorization path.
6. Is it a cloud service sold to a federal agency? → FedRAMP path.
7. Does it include an AI/ML component that influences decisions about people? → AI overlay; [LEGAL REVIEW REQUIRED] for EU AI Act / state AI law tier.
8. Does a customer contract impose specific requirements beyond the above? → [CONTRACT REVIEW REQUIRED]; record in the Compliance Obligations Register.
9. None of the above? → Core baseline only (CSF / ISO / 800-53 / CIS IG tier per data classification).

8. Assumptions and Decisions Log

#	Assumption / decision	Basis	Status
A-01	Composite mid-to-large private enterprise (~2,500 staff), US-headquartered, EU customers	Sized to justify full program maturity; portfolio intent confirmed	Open — confirm or adjust
A-02	All major data types (PII, PHI, PCI, CUI, IP) in scope simultaneously	Explicit instruction: 'any and everything'	Confirmed
A-03	No current federal contract; federal/CUI track built as an inactive module	Explicit instruction to keep commercial and federal separable	Confirmed
A-04	Greenfield — no existing security program	Explicit statement	Confirmed
A-05	Hybrid technology stack: on-prem AD + Azure (Entra/Intune/Defender) + AWS Linux + SaaS + CI/CD	Modeled on a common enterprise pattern; can be decoupled from any real environment on request	Open — confirm
A-06	Private company; SEC disclosure module excluded	Default; not yet confirmed	Open — confirm or add SEC module
A-07	Not a financial institution; GLBA / NYDFS / FFIEC excluded	Default; not yet confirmed	Open — confirm or add finance overlay
A-08	One internal AI copilot; no consequential automated decisions about people	Keeps AI overlay narrow	Open — confirm
A-09	Output: Word (.docx), one file per document	Established pattern	Confirmed
A-10	Learning Mode ON	Master method default; confirmed	Confirmed
D-01	NIST SP 800-53 Rev. 5 selected as the single authoritative control library	Section 3 rationale	Decided — Gate 3 will confirm tailoring
D-02	Overlays never restate core controls; they add incremental requirements only	Prevents duplicate/conflicting controls	Decided

9. Gate 1 Sign-Off

The master method requires legal, privacy, contracts, and management validation of applicability before the unified control library is built. In a portfolio build this validation is simulated; the block is retained so the artifact demonstrates correct governance discipline to a reviewer.

Reviewer role	Name	Date	Disposition
Legal Counsel	[Insert]	[Insert]	Approve / Approve with changes / Reject
Privacy Officer	[Insert]	[Insert]	Approve / Approve with changes / Reject
Contracts / Procurement	[Insert]	[Insert]	Approve / Approve with changes / Reject
CISO / Program Owner	[Insert]	[Insert]	Approve / Approve with changes / Reject

10. Revision History

Version	Date	Author	Change
1.0	2026-09-03	S. Smith	Initial draft
1.1	2026-10-22	S. Smith	Rebuilt: full obligation record fields; split register by authority type; added version register, decision tree, document-control block; added AI-law and insurance rows

Learning Mode Note

CISO lens

This register is what lets a CISO answer 'why does the program cover what it covers' in one sentence to a Board, and 'why doesn't it cover X' to a regulator. Without it, programs drift toward implementing whatever the last auditor asked for — which wastes budget on unnecessary controls and, worse, can miss ones the organization is legally required to have.

ISSO lens

Every system-level SSP inherits its baseline from Sections 4 and 5. FIPS 199 categorization in Phase 6 should trace to which data categories the system touches here — not be re-derived per system. The Section 7 decision tree is the onboarding checklist for any new system entering the boundary.

Challenge questions

- You list 800-171 Rev. 3 but many DoD contracts still incorporate Rev. 2. Which revision governs, and how do you handle the gap until the contract is modified?
- HIPAA and PCI both require encryption at rest. Show me the single control in the library that satisfies both, and the evidence that proves it.
- Your federal track is inactive. What is the first document that changes the day a contract with DFARS 7012 is signed, and who owns that change?

Common failure

Writing the full policy library before this register exists. The documents look complete but collapse when someone asks what was decided to be out of scope and why — because nothing was decided; it was assumed.

Field use — first 90 days

In a real organization, build this in week one from three inputs: every executed contract with a security addendum or DPA, the actual list of data types collected (from Legal/Privacy, not IT's guess), and prior audit or assessment findings. Those three resolve most Not Applicable rows and every [CONTRACT REVIEW REQUIRED] marker.